

Contoso - Compliance & Risk Assessment Checklist

Document ID: AC-COMP-CHK-2024-001 **Version:** 2.1 **Effective Date:** January 1, 2024 **Last Reviewed:** December 1, 2023 **Owner:** VP Compliance & Risk Management **Classification:** Internal - Confidential

Purpose

This checklist provides a structured framework for assessing vendor and contract compliance across all regulatory and risk domains relevant to Contoso's operations. It should be used in conjunction with the Corporate Procurement Policy (AC-PROC-POL-2024-001) and the Legal Review Playbook (AC-LEGAL-PLB-2024-001).

1. Tax Compliance

1.1 domestic Tax Requirements

#	Requirement	Verification	Applies To
T-01	Vendor provides valid Sales Tax registration number	Verify via tax authority business number search	All vendors with taxable supplies
T-02	Sales Tax registration number provided (locally-based services)	Verify via regional tax authority	Vendors providing services in the local jurisdiction
T-03	Invoices comply with tax authority input tax credit requirements	Review invoice format and content	All invoices
T-04	Provincial tax allocation is correct for multi-state services	Review tax breakdown on invoices	Vendors operating in multiple states
T-05	Vendor provides valid Business Number (BN)	Verify with tax authority	All domestic vendors

1.2 Cross-Border Tax Requirements

#	Requirement	Verification	Applies To
T-06	Tax department review completed for cross-border contracts > \$50K	Tax department sign-off on file	International vendors, contracts > \$50K
T-07	Withholding tax obligations addressed (applicable withholding tax)	Contract clause review; applicable withholding tax filings prepared	Non-resident vendors performing services domestically
T-08	Applicable tax treaty benefits documented	W-8BEN-E or equivalent on file	US and treaty-country vendors
T-09	Permanent establishment risk assessed	Tax department assessment on file	Vendors with extended presence domestically
T-10	Transfer pricing documentation in place	Transfer pricing policy and benchmarking study	Intercompany / related-party agreements

1.3 Enterprise-Specific Tax

#	Requirement	Verification	Applies To
T-11	Service surcharges and industry levies separately identified	Invoice review	Service and logistics vendors
T-12	Logistics service tax treatment verified by jurisdiction	Tax department review	Logistics service providers
T-13	International regional service tax implications assessed	Bilateral service agreement review	International region-specific vendors
T-14	Facility improvement fees and infrastructure services charges properly classified	Invoice review	Facility and infrastructure service providers

2. Insurance Compliance

2.1 General Insurance Requirements

#	Requirement	Verification	Applies To
I-01	Certificate of insurance provided before contract commencement	Certificate on file; date verified	All vendors (contracts > \$25K)
I-02	Insurance certificates renewed annually	Annual certificate tracking in system	All active vendor contracts
I-03	Contoso named as additional insured on CGL	Certificate review	All vendors
I-04	30-day cancellation notice provision confirmed	Certificate and policy endorsement review	All vendors
I-05	Insurer rated A- (Excellent) or better by AM Best	AM Best rating verification	All vendors
I-06	Deductibles within acceptable range (< \$100K or approved)	Certificate review; Procurement Director approval if > \$100K	All vendors
I-07	Claims-made policies maintained for 2 years post-termination	Contractual obligation; certificate tracking	Vendors with claims-made policies

2.2 Coverage Minimums by Contract Type

#	Contract Type	CGL	Professional Liability	Cyber/Tech E&O	Workers' Comp	Auto
I-08	General Services	\$2M/\$5M	-	-	Statutory	\$2M
I-09	Professional/Consulting	\$2M/\$5M	\$5M/\$10M	-	Statutory	\$2M

I-10	Technology/SaaS	\$2M/\$5M	\$5M/\$10M	\$10M	Statutory	-
I-11	Construction/Facilities	\$5M/\$10M	\$5M	-	Statutory	\$5M
I-12	Enterprise Services (On-site)	\$10M/\$25M	\$10M	-	Statutory	\$5M
I-13	Data Processing	\$2M/\$5M	\$5M	\$15M	Statutory	-

3. Cybersecurity Compliance

3.1 Mandatory Certifications

#	Requirement	Evidence Required	Applies To
C-01	SOC 2 Type II certification (current, within 12 months)	SOC 2 report from accredited firm	Technology vendors accessing AC systems/data
C-02	ISO 27001 certification	Valid certificate from accredited body	Vendors processing or storing AC data
C-03	PCI DSS compliance (if processing payment data)	PCI DSS Attestation of Compliance (AOC)	Payment processing vendors

3.2 Data Security Controls

#	Requirement	Verification	Applies To
C-04	Encryption at rest: AES-256 or equivalent	Vendor security questionnaire; SOC 2 report review	All technology vendors
C-05	Encryption in transit: TLS 1.2 or higher	Technical assessment or vendor attestation	All technology vendors
C-06	Multi-factor authentication (MFA) for AC system access	Technical verification; vendor policy review	All vendors with AC system access
C-07	Role-based access control (RBAC) implemented	Vendor security questionnaire	All technology vendors
C-08	Data masking/tokenization for sensitive data in non-production environments	Technical assessment	Vendors with access to PII or financial data

3.3 Data Residency

#	Requirement	Verification	Applies To
C-09	All AC data stored within the domestic jurisdiction	Vendor attestation; data centre location verification	All technology vendors (default)

C-10	CISO approval obtained for any non-domestic storage	Written CISO approval on file	Exceptions only
C-11	Data processing locations documented	Vendor disclosure; contractual commitment	All technology vendors
C-12	Sub-processor locations disclosed and approved	Sub-processor list on file	Cloud/SaaS vendors

3.4 Vulnerability and Incident Management

#	Requirement	Verification	Applies To
C-13	Annual third-party penetration test completed	Pen test report (summary) shared with AC	All technology vendors
C-14	Critical vulnerabilities remediated within 72 hours	Vendor policy review; incident reports	All technology vendors
C-15	High-severity vulnerabilities remediated within 30 days	Vendor policy review	All technology vendors
C-16	Documented incident response plan	Plan document or summary on file	All technology vendors
C-17	24-hour breach notification to Contoso	Contractual clause verified	All technology vendors
C-18	Full incident report within 72 hours	Contractual clause verified	All technology vendors

3.5 Security Assessments

#	Requirement	Verification	Applies To
C-19	Right to audit clause in contract	Contract review	All technology vendors
C-20	Security questionnaire completed (initial and annual)	Completed questionnaire on file	All technology vendors
C-21	Security assessment completed for Tier 1 vendors	Assessment report on file	Tier 1 technology vendors

4. Regulatory Compliance

4.1 Privacy (Data Privacy Regulation / Regional Privacy Regulation)

#	Requirement	Verification	Applies To
R-01	Privacy impact assessment (PIA) completed	PIA document on file	Contracts involving personal information

R-02	Data processing agreement (DPA) executed	DPA signed by both parties	Vendors processing personal information
R-03	Data Privacy Regulation compliance warranty in contract	Contract clause review	All contracts involving personal data
R-04	Regional Privacy Regulation compliance for local residents' data	Contract clause review; vendor attestation	Contracts involving local residents' data
R-05	Cross-border transfer safeguards in place	CISO/Privacy Office approval; contractual safeguards	Vendors transferring personal data outside the domestic jurisdiction
R-06	Privacy breach notification protocol established	Contract clause; tested procedure	All vendors handling personal information

4.2 Enterprise-Specific Regulations

#	Requirement	Verification	Applies To
R-07	Industry regulatory compliance verified	Current certificates on file	Enterprise service providers
R-08	Industry Standards Body industry safety audit registration verified (ground operations)	Current industry safety certificate	Logistics service providers
R-09	Facility authority compliance requirements met	Facility-specific clearances on file	On-site service providers
R-10	Secure area clearance for on-site personnel	Security clearance verification for all personnel	On-site vendors
R-11	Safety Management System alignment	Safety management documentation review	Enterprise safety-critical vendors
R-12	Security Authority security requirements met (if applicable)	Security Authority compliance verification	Security-related vendors

4.3 Anti-Corruption and Sanctions

#	Requirement	Verification	Applies To
R-13	applicable anti-corruption laws compliance warranty in contract	Contract clause review	International vendors; contracts > \$100K
R-14	Sanctions screening completed	Screening results on file (applicable government sanctions authorities, OFAC, UN, EU)	All vendors
R-15	Beneficial ownership verified	Beneficial ownership disclosure on file	Tier 1 and Tier 2 vendors

R-16	Anti-corruption training completed by vendor	Vendor attestation	Tier 1 vendors; high-risk jurisdictions
------	--	--------------------	---

4.4 Competition Law

#	Requirement	Verification	Applies To
R-17	No exclusive dealing without CEO/GC approval	Contract review; approval on file	All contracts
R-18	Competition law review for joint ventures/partnerships	External counsel opinion	Joint ventures, strategic partnerships

5. ESG / Sustainability Requirements

5.1 Environmental

#	Requirement	Verification	Applies To
E-01	Vendor environmental policy on file	Policy document review	Tier 1 vendors
E-02	Carbon footprint reporting	Vendor's annual sustainability report or carbon disclosure	Tier 1 vendors; contracts > \$1M
E-03	Compliance with domestic Environmental Protection Act (CEPA)	Vendor attestation	Vendors handling hazardous materials
E-04	Waste management and recycling practices documented	Vendor questionnaire	Facilities and operations vendors
E-05	Alignment with Contoso's sustainability commitment	Vendor sustainability assessment	Tier 1 vendors; strategic partners

5.2 Social

#	Requirement	Verification	Applies To
E-06	Labour standards compliance (domestic Labour Code or equivalent)	Vendor attestation	All vendors
E-07	Diversity and inclusion policy on file	Policy document review	Tier 1 vendors
E-08	No use of forced or child labour (Modern Slavery Act compliance)	Vendor attestation; supply chain disclosure	All vendors; especially international
E-09	Indigenous engagement and procurement practices	Vendor questionnaire	Tier 1 vendors; relevant sectors

5.3 Governance

#	Requirement	Verification	Applies To
E-10	Corporate governance structure disclosed	Governance overview on file	Tier 1 vendors
E-11	Code of conduct / ethics policy on file	Policy document review	Tier 1 and Tier 2 vendors
E-12	Whistleblower / ethics reporting mechanism in place	Vendor attestation	Tier 1 vendors

6. Assessment Scoring

6.1 Compliance Scoring Matrix

Score	Rating	Definition
90-100%	Compliant	All applicable requirements met. Proceed with contracting.
75-89%	Substantially Compliant	Minor gaps identified. Remediation plan required; may proceed with conditions.
50-74%	Partially Compliant	Significant gaps. Remediation required before contract execution. Escalate to VP.
< 50%	Non-Compliant	Fundamental gaps. Do not proceed. Escalate to General Counsel and VP Risk Management.

6.2 Domain Weighting

Domain	Weight
Tax Compliance	15%
Insurance	20%
Cybersecurity	25%
Regulatory (Privacy, Enterprise, Anti-Corruption)	25%
ESG / Sustainability	15%

7. Assessment Frequency

Vendor Tier	Initial Assessment	Ongoing Assessment
Tier 1 - Critical	Full assessment before contracting	Annual comprehensive review
Tier 2 - Significant	Full assessment before contracting	Biennial review
Tier 3 - Standard	Targeted assessment (relevant domains)	Triennial review or upon renewal

Tier 4 - Low	Simplified screening	Upon renewal only
--------------	----------------------	-------------------

This checklist is reviewed annually by the Compliance & Risk Management team. Questions should be directed to compliance.risk@contoso.com.

Last approved by: Nathalie Fournier, VP Compliance & Risk Management - December 1, 2023